



by **John Leyden**
Senior Writer

Microsoft wants you to rethink your approach to cyber defense

News Analysis

Aug 13, 2026 • 7 mins

When finding vulnerabilities and generating targeted exploits is a 21-minute job that costs just \$3.61, it's time to scrap outdated best practices and 'hand-to-hand combat with attackers,' warns Redmond's AI security lead.



Credit: Andrey_Popov / Shutterstock

Cyber defenders need to shake off traditional best practices and switch from reactive patching to building inherently resilient systems in the face of AI-accelerated vulnerability discovery, according to a senior security manager at Microsoft.

David Weston, group manager in the Windows team at Microsoft, told delegates at Black Hat USA that traditional approaches to **vulnerability remediation** [<https://www.csoonline.com/article/526536/vulnerability-management-the-basics.html>] fail to work in an era when AI tools are making vulnerability discovery and exploit development cheaper, faster, and more scalable.

Weston's keynote — entitled "**The End of Rare: Defending When Offense Is Cheap** [<https://blackhat.com/us-26/features/schedule/index.html?track%5b%5d=keynotes&track%5b%5d=main-stage#keynote-the-end-of-rare-defending-when-offense-is-cheap-56597>]" — challenged industry vulnerability best practices that Weston said were from a time when developing exploits and mounting attacks was time consuming and expensive. That's no longer the case, he said.

As evidence, Weston explained how the Microsoft Security Response Center (MSRC) is doubling the number of vulnerabilities it processes and patches every six weeks. "That is an incredible number," he said. "We're nine times the vulnerability volume that we were in March."

The accelerating pace of vulnerability discovery is "highly correlated" to rising use of increasingly capable AI tools, and presents a cross-industry problem, he said.

"These are serious vulnerabilities, the kind that I used to take a year to bespoke craft," Weston pointed out. "They're being spit out at industrial speed, and it's not [just] Windows. You look at Linux, you look at any other operating system out there, I think you'll see a pretty strong correlation."

Microsoft's MDASH [<https://www.csoonline.com/article/4180467/microsoft-wants-to-put-ai-agents-on-a-short-leash.html>], short for Multi-model Agentic Scanning Harness, found roughly 200 Linux kernel vulnerabilities in the company's internal Azure Linux distribution that Microsoft is working with the community to fix.

Microsoft also added a new module to MDASH to help its engineers triage vulnerabilities. The technology is capable of turning a static analysis result into proof-of-concept exploit code.

"That's worked much better than we ever thought," said Weston, who leads Microsoft's AI vulnerability-discovery and frontier-model research. "Of the 200 vulnerabilities, we can automatically generate 182 crash-level POCs. Many of them are fully working exploits. I'm talking root exploits automatically spit out from vulnerability."

The average computing cost of detecting those vulnerabilities and generating their exploits was just \$3.61, with a time to generation of 21 minutes.

Microsoft's work provides further evidence that developing an exploit from a security vulnerability is not likely a factor holding back any attackers with access to advanced AI-based security tools.

"By the end of the year, we'll be looking at automatic exploit generation being pretty commonplace and pretty commodity," Weston warned.

Traditional mitigations failing

Nondeterministic mitigations that introduce randomness or unpredictability, such as ASLR (Address Space Layout Randomization), may continue to be an obstacle for attackers but are not likely to stem the rising tide of AI-mediated vulnerability discovery for long.

Enterprises have historically relied heavily on threat detection for defense, but that layer of protection assumes attackers face cost and time challenges in changing the tools and techniques they use. Those comforting assumptions are also being undermined by AI, Weston said.

The idea used to be that it's "super expensive to code a framework or an implant, so people just keep using packers and obfuscation tools on the same stuff, and they keep using the same TTP, so we'll work against that. And that's gonna give us durability in detection," Weston said.

"Instead of having to retrain the operator, which would have been expensive for cyber operations, we can just use autonomous operations," he noted of attackers' evolving mentality. "Instead of obfuscating, we can create a bespoke set of tools or frameworks per target."

How to turn the table on attackers

In response to the changing economics of security, the industry must adopt memory-safe computer programming languages such as Rust alongside the use of AI-based tools to improve the resilience of existing code bases.

"We don't wanna go vulnerability for patch," Weston argued. "We don't want to go exploit for detection, evasion for detection. Hand-to-hand combat with attackers will cause us to lose in defense."

About 70% of vulnerabilities that are patched today, at least by the major vendors, are memory safety issues. Safer computer programming languages, such as Rust and Golang, "eliminate those," according to Weston. For example, **Google reduced memory safety flaws [https://blog.google/security/rust-in-android-move-fast-fix-things/] from 76% of Android vulnerabilities in 2019 to below 20% in 2025 after it switched to Rust.**

More recently, Microsoft rewrote the Azure hypervisor, the software that isolates virtual machines from one another, using Rust, and scaled it across 1.5 million virtual machines without any adverse incident.

A project from the **Defense Advanced Research Projects Agency** [<https://www.darpa.mil/news/2024/memory-safety-vulnerabilities>], called Tractor, automates the conversion of legacy C code into Rust. Microsoft Research's **AI-based project RustAssistant**, [<https://www.microsoft.com/en-us/research/publication/rustassistant-using-llms-to-fix-compilation-errors-in-rust-code/>] introduced last year, uses AI-based technology to detect and suggest remedies for Rust compilation errors.

Weston added: "We can shift left and make more secure software. That'll limit vulnerability."

Detection of attacks is still important but no longer sufficient. Both enterprises and vendors should be investing in durability.

"We can move to more prevention mechanisms," Weston said. "And we can use secure by construction and even formal methods to get the deterministic safety. If we can do that along a realistic timeline, then we can turn the tables and drive this problem towards attackers."

Vulnerability research in the age of AI

Yan Shoshitaishvili, an associate professor at Arizona State University and well-known vulnerability researcher, presented a Black Hat USA keynote on how **agentic AI is drastically reducing** [<https://www.csoonline.com/article/4207666/the-future-of-ai-security-research-isnt-autonomous-its-human-amplified.html>] the cost and time required to discover and exploit vulnerabilities.

The talk — "**Vulnerability Research in the Agentic Age** [<https://blackhat.com/us-26/features/schedule/index.html?track%5b%5d=keynotes#keynote-vulnerability-research-in-the-agentic-age-55627>]" — offered a companion piece to Weston's presentation. AI tools have shifted the human skills in bug hunting toward developing better search strategies, validation pipelines, and exploitability checks.

"Going from asking GPT to find bugs, to having an agentic pipeline that's vulnerability-aware requires human innovation, human understanding of the threat models, of the vulnerability space," Shoshitaishvili said.

He and his research student Hong Kai Chen applied these techniques to a study on OpenHarmony, the open-source foundation behind parts of Huawei's commercial HarmonyOS ecosystem for mobile devices.

"We found dozens of flaws, ranging from Bluetooth, device takeovers, to privacy leaks, location, all of this, very fun stuff, in Open Harmony, because we started from the

vulnerability properties that we extracted from Android bugs,” Shoshitaishvili said. “Now we’re doing this agentially, and the results are incredible.”

With agentic pipelines, Shoshitaishvili’s team is finding vulnerabilities far faster than they can responsibly disclose with accompanying documentation and proposed fixes. Shoshitaishvili tested the “just rewrite everything in Rust” idea using agentic code generation on a Rust rewrite of `coreutils` shipped with Ubuntu. His team found that memory-safety bugs (buffer overflows, use-after-free) were largely gone but logic vulnerabilities, such as time-of-check–time-of-use (TOCTOU) races and cryptographic, reappeared.

Rewriting in a safer language removes some classes of bugs but not the underlying design-level weaknesses unless active steps to rewrite problematic code are undertaken, Shoshitaishvili concluded.

[Threat and Vulnerability Management](https://www.csoonline.com/threat-and-vulnerability-management/)

[Security](https://www.csoonline.com/security/)

[Security Practices](https://www.csoonline.com/security-practices/)

About



Policies



More



Our Network





© 2026 FoundryCo, Inc. All Rights Reserved.